Who Is Watching the Solar Farm’s Network?

Part A — Research Report | Cognton AI Full-Time Hiring Exercise

A research-led design for passive OT security monitoring in a distributed renewable-energy park

Prepared: 22 October 2026

Prepared as a technical research and prototype-design proposal. No real industrial network was tested.

Executive Summary

This report evaluates a low-cost, passive security-monitoring “watchman” for a multi-developer renewable-energy park in western Gujarat. The target environment contains heterogeneous inverters, meters, weather stations, field controllers, plant SCADA, vendor remote access and links to pooling substations and grid-control systems. The core problem is limited visibility across vendor boundaries, industrial protocols and lightly staffed control rooms.

The proposed design combines passive network visibility, protocol-aware parsing, a baseline asset inventory, deterministic policy rules, explainable anomaly detection and a central alert dashboard. Site-level processing should continue during WAN degradation; only prioritized alerts and compact summaries need to travel centrally. The design is deliberately advisory: it detects and escalates suspicious activity rather than automatically changing control equipment.

The research supports five practical principles: (1) protect safety and availability before adding security controls; (2) use passive monitoring where possible; (3) combine rules with anomaly detection rather than relying on ML alone; (4) treat vendor access and firmware integrity as separate control areas; and (5) validate detection in an isolated lab before any operational deployment. This report is a research and design proposal, not evidence of a tested product or a claim of compliance certification.

Scope note: the hiring exercise’s detailed Part A deliverable and final checklist specify 12–20 pages. This report follows that detailed requirement. The assignment overview on page 1 contains a conflicting 6–10 page summary.

1. Problem Definition and System Context

1.1 Operational setting

The assignment describes a large renewable-energy park split among multiple developers using equipment from different vendors. Inverters, meters, weather stations and sensors communicate over plant networks to an Inverter Control Room (ICR). SCADA software supervises operations remotely, while power flows through pooling substations into the grid. Control rooms may be mostly unmanned, and developers may not share a single security team.

1.2 Why conventional visibility is insufficient

Traditional IT tools may not interpret industrial command semantics, such as which host is writing a particular inverter register. Older industrial protocols may not authenticate each command, so network reachability can become a security boundary. Commercial OT monitoring may also be difficult to deploy at every small site due to budget, staffing, connectivity and vendor heterogeneity. These are design constraints to validate for each site, not assumptions that every plant has the same weaknesses.

1.3 Product hypothesis

A small passive sensor at each ICR can learn observed assets and communications, identify policy violations and suspicious patterns, and forward useful alerts to a central dashboard. The sensor must not inject packets into the control network or block traffic in the first prototype. A later production design would require engineering review, asset-owner approval, fail-safe deployment and a formal operational change process.

1.4 Goals and non-goals

- Goals: asset discovery; protocol visibility; unknown-device alerts; detection of unauthorized writes and abnormal traffic; explainable alerts; central multi-site view; operation over constrained links.
- Non-goals for the prototype: controlling inverters, replacing safety systems, automatically isolating production devices, proving protection against every attack, or claiming formal compliance certification.
- Primary safety constraint: all active attack simulations remain inside an isolated local lab. Never scan, probe or attack a real industrial network.

A1 — Reference Architecture and Protocol Map

2.1 Proposed architecture

The diagram below is a reference design, not a vendor-specific wiring diagram. Purdue levels are approximate because actual sites vary. Confirm the plant's approved architecture, routing and protocol variants with the asset owner.

Reference flow (left to right): Field assets → control devices → ICR/SCADA → site operations → pooling/grid interface. The passive sensor observes approved mirror/TAP points and forwards alerts to the central dashboard.

Layer	Example components	Purdue level	Protocol examples
Field layer	Panels / sensors / meters	Purdue 0–1	Modbus RTU/TCP; vendor-specific telemetry
Control layer	Inverters / PLCs / RTUs	Purdue 1–2	Modbus TCP; vendor protocol; IEC 61850 where deployed
Supervisory layer	ICR switch / data logger / HMI / SCADA	Purdue 2	Modbus TCP; OPC UA; MQTT; vendor interfaces
Site operations	Historian / engineering workstation / jump host	Purdue 3	OPC UA; HTTPS/RDP/SSH through approved gateway
Grid interface	Pooling substation / grid control centre	Purdue 3–4 (site-dependent)	IEC 60870-5-104; IEC 61850; DNP3 where applicable
Security plane	Passive TAP/SPAN → sensor → local event store → central dashboard	Observes across approved mirror points	Zeek + ICS parsers and/or Suricata; HTTPS outbound summaries

Security plane: approved TAP/SPAN → passive sensor → local event store → central dashboard (outbound summaries only).

2.2 Vendor remote-access path

Preferred pattern: vendor user → identity provider with MFA → approved remote-access gateway/jump host → time-limited, ticketed session → specific engineering workstation or device. Record session metadata and, where legally and technically appropriate, session activity. Do not expose controller interfaces directly to the public internet. The sensor should observe this path and alert on access outside approved windows, unexpected source assets or unusual engineering actions.

2.3 Device and protocol inventory

Component	Likely role	Protocol examples	Security observation
Inverter	Converts DC to AC; set-point/control	Modbus TCP or vendor-specific	Read/write semantics and allowed controller sources matter.
Meter / weather station	Measurement and telemetry	Modbus, vendor protocols	New endpoints or changed polling patterns can be useful indicators.
PLC / RTU	Field control and telemetry aggregation	Modbus; IEC-104; IEC 61850 by design	Protect engineering access and controller configuration.
HMI / SCADA	Operator supervision and commands	Vendor protocols; OPC UA; Modbus	Commands should originate from known supervisory hosts.
Historian / data logger	Stores time-series values	OPC UA; SQL; vendor APIs	Unexpected outbound connections and data gaps may matter.
Vendor gateway / jump host	Remote maintenance access	HTTPS, RDP, SSH, VPN	MFA, time limits, approval and audit trails are essential.
Grid interface	Substation/control-centre exchange	IEC-104 / IEC 61850 / DNP3 as deployed	Verify actual standard, profile and security extensions.

2.4 Purdue Model cautions

The Purdue Model is a segmentation and communication reference, not a guarantee that a given protocol belongs to one fixed level. Protocol selection depends on plant design, vendor equipment, legacy constraints and the utility's interface

requirements. Label the actual observed path in the prototype and mark uncertain placements as assumptions.

A2 — Inspecting Industrial Traffic with Wireshark

3.1 Research method

Use public ICS packet captures supplied for education or research, such as the Netresec 4SICS collection or the ITI ICS-Security-Tools repository referenced by the assignment. Open the capture in Wireshark, filter by protocol and inspect packet details. Save screenshots that show the selected packet, protocol fields, source/destination and timestamp. Record the capture name, source URL, date accessed and any licensing conditions.

3.2 Required packet examples

Example	What to locate	What to record	Security interpretation
Modbus read	A request using a read function (for example, read holding registers) and its response	Source/destination, unit ID, function code, register start/count, response	Unexpected source or polling pattern may be suspicious; reads can reveal process data.
Modbus write	A write-single or write-multiple-registers request and response	Function code, target register/address, value(s), source and timestamp	Writes should be constrained by role, device, register and approved time.
IEC-104 command	A control-direction ASDU/command in an applicable capture	C_IC/C_SC or other observed ASDU, cause of transmission, common address, IOA, source/destination	Check whether the command is expected and authorized; do not infer semantics without the packet profile.

3.3 Authentication findings

Classic Modbus TCP does not inherently authenticate each command or provide cryptographic confidentiality. IEC 60870-5-104 deployments also require careful assessment of the base protocol and any implemented security extensions, network segmentation and gateway controls. Do not write that every deployment is unauthenticated: protocol variants, secure profiles, wrappers and compensating controls can change the risk. Verify the specific implementation and configuration.

3.4 Safe interpretation

A packet capture can show what was transmitted, but it may not prove intent or physical impact. A write packet is not automatically malicious; it may be legitimate operator activity. Detection should correlate source identity, register policy, maintenance window, process context and known baseline. Do not replay packets against real equipment. For the prototype, use only simulated devices in an isolated lab.

3.5 Screenshot checklist

- Capture file and provenance are documented.
- Packet list shows time, source, destination and protocol.
- Packet details expose the relevant function/ASDU and register or object fields.
- Annotations explain normal behavior, suspicious variation and uncertainty.
- Sensitive identifiers are redacted where appropriate; no production credentials are included.

A3 — Real Incidents and Solar-Park Attack Scenarios

4.1 Case-study summary

Incident	High-level lesson	Relevant ATT&CK for ICS themes	Relevance to solar park
Ukraine grid attacks (2015)	Intrusions and coordinated actions disrupted electricity distribution; operational and recovery planning mattered.	Initial Access; Execution; Impair Process Control; Impact	Credential misuse, control-system access, operator visibility and recovery drills.
Industroyer/CrashOverride (2016)	Malware was designed to interact with power-system protocols and substation equipment.	Execution; Discovery; Command and Control; Impair Process Control; Impact	Protocol-aware monitoring is needed; generic port alerts may miss command meaning.
Industroyer2 (2022)	A later destructive attempt targeted power operations using industrial-protocol knowledge.	Execution; Impair Process Control; Impact	Baseline expected control commands and alert on unexpected command sequences.
TRITON/TRISIS (2017)	An attack targeted a safety instrumented system, highlighting the consequence of compromising safety-related engineering paths.	Initial Access; Execution; Inhibit Response Function; Impact	Separate safety networks and engineering access; do not treat a passive IDS as a safety system.
KA-SAT outage (2022)	A satellite communications disruption affected remote connectivity, including wind-turbine monitoring in Germany, as reported publicly.	Impact; inhibit/interrupt communications (map exact technique after evidence review)	Local operation and buffered events should continue during WAN loss.
RedEcho reporting (2021)	Public reporting described suspected targeting of Indian power-sector organizations; attribution claims should be presented with source and confidence.	Discovery; Command and Control; Initial Access (only where supported by evidence)	Threat intelligence can inform hypotheses but should not be treated as proof of compromise.
Volt Typhoon	Public advisories describe stealthy access and living-off-the-land behavior in critical infrastructure contexts.	Initial Access; Persistence; Discovery; Command and Control, depending on observed behavior	Use behavior and context, not only malware signatures; avoid over-attributing generic activity.

4.2 ATT&CK mapping approach

MITRE ATT&CK for ICS organizes adversary behavior by tactical goal and technique. Map only techniques supported by the incident sources; distinguish confirmed behavior from inferred or reported behavior. A single incident can map to multiple tactics, and a tactic label is not proof that a particular technique occurred.

4.3 Solar-park scenarios (10)

ID	Scenario	Potential detection logic	Prototype priority
S1	Unknown laptop appears in ICR	New IP/MAC or previously unseen device communicating with industrial assets	Must-have
S2	Unauthorized Modbus write to inverter set-point	Write function from source not on allowlist or register outside permitted policy	Must-have
S3	Write occurs outside approved maintenance window	Write event time compared with change ticket / allowed schedule	Must-have
S4	Vendor remote session from unexpected source or time	Gateway/session logs plus traffic context; alert on policy mismatch	High; simulated if gateway logs available
S5	Unexpected firmware/configuration change	Compare vendor-supported version/hash/configuration records; network traffic alone may not prove firmware integrity	High; needs endpoint/vendor evidence
S6	IEC-104 command from an unexpected host	Command ASDU from source not approved for that control function	Must-have if protocol is represented in lab
S7	Traffic flood or scan-like burst inside lab	Rate/connection threshold and deviation from baseline; avoid active scanning of real networks	Must-have
S8	Industrial device starts talking to an unusual destination	Destination/port/periodicity deviates from known asset profile	Medium

ID	Scenario	Potential detection logic	Prototype priority
S9	Loss of expected telemetry or communications	Polling gap, missing heartbeat, or sudden drop in event rate	Medium
S10	Sensor/dashboard WAN link fails	Local buffering, health alert and store-and-forward after recovery	Medium; supports slow-link design

4.4 What the prototype can and cannot prove

Packet-level monitoring can detect unknown assets, unexpected protocol use, suspicious writes and traffic deviations. It cannot reliably verify firmware integrity solely from ordinary network traffic, and it may not identify a physical intrusion without door/access-control telemetry. For S4/S5, integrate simulated gateway logs or inventory/configuration evidence and clearly mark the data source. A credible report states these limits instead of claiming every scenario is detectable from packets alone.

A4 — Dataset Comparison and Data Requirements

5.1 Dataset selection criteria

Compare datasets by protocol coverage, plant similarity, size, labels, repeatability, access conditions, licence and whether the raw data includes packets or only derived sensor values. “Industrial” does not automatically mean “representative of a solar farm.” A dataset may be valuable for anomaly-method experiments while still being unsuitable for direct protocol-parser testing.

Dataset/source	Likely value	Limitations / checks	Use recommendation
CIC Modbus 2023 (as named in assignment)	Potentially relevant Modbus traffic and attack-labelled examples	Confirm official release page, capture format, label definitions, licence and reproducibility before citing figures	Candidate for parser/rule testing after provenance check
HAI (Hardware-in-the-Loop Augmented ICS)	Time-series process/control data with normal and attack periods	May emphasize process variables rather than raw network packets; check release version and terms	Useful for process-anomaly research; not a replacement for pcap tests
SWaT	Water-treatment ICS testbed data and attacks	Different physical process; access may require registration/request; dataset fields and terms vary	Useful for anomaly-method comparison, not solar-specific validation
WADI	Water-distribution testbed data	Different process and sensor semantics; check current access/licence	Supplementary time-series evaluation
Electra (as named in assignment)	Potentially power-system / electric-grid security relevance	Verify exact dataset identity, institution, protocol and public availability; name alone is ambiguous	Use only after resolving provenance
DNP3 intrusion dataset (Zenodo)	Could support DNP3-focused traffic or event analysis	Check release record, protocol fidelity, attack labels and licence	Relevant only if DNP3 is in scope
Mississippi State power-system datasets	Power-system cyber-physical research examples	Multiple datasets exist; identify exact dataset, simulation assumptions and terms	Useful for power-system attack context after exact selection
IEC-104 datasets	Potential command/telemetry evidence for IEC-104 parsing	Availability and labels may differ; validate each source individually	Prioritize if IEC-104 is implemented in the lab

5.2 Recommended strategy

For the first prototype, use two complementary sources: (1) controlled lab-generated pcaps from the simulated Modbus TCP and IEC-104 environment, which provide repeatable labels and match the demo architecture; and (2) one public dataset chosen after licence and format verification, used as a secondary benchmark. Avoid training an ML model on an unrelated process dataset and claiming that its accuracy transfers directly to a solar farm.

5.3 Data available from a real ICR

- Packet captures or Zeek/Suricata event logs from approved mirror ports/TAPs.
- Switch forwarding/MAC tables, DHCP records and approved asset inventory.
- SCADA/HMI alarms, historian values and polling/communications status.
- Inverter register maps, read/write audit records and vendor configuration/firmware records, where available.
- Remote-access gateway logs, identity/MFA events, change tickets and maintenance windows.
- Sensor health, local queue depth, clock synchronization status and WAN availability.

5.4 Data governance

Minimize collection of credentials and unrelated user data. Define retention, access controls, clock synchronization, integrity protection and redaction. Obtain permission for every capture and dataset. Treat packet captures as potentially sensitive operational information even if payloads are not encrypted.

A5 — Standards, Compliance and Incident Playbook

6.1 Standards and regulatory references

Reference	Role in the design	Implementation note
NIST SP 800-82 Rev. 3	Guidance for securing OT while respecting performance, reliability and safety needs	Use for architecture, risk assessment, segmentation, monitoring and response planning; it is guidance, not Indian law.
ISA/IEC 62443 series	Industrial automation/control-system security requirements and lifecycle practices across asset owners, suppliers, integrators and service providers	Map relevant parts to the organization's roles and risk assessment; do not claim certification from this report.
CEA Cyber Security in Power Sector Guidelines (2021)	India-specific power-sector cybersecurity guideline referenced in the assignment	Review the official document and applicable current CEA instruments; confirm applicability and any updates with the responsible compliance team.
CERT-In Directions (28 Apr 2022) and FAQs	Incident reporting and log-related directions for covered entities	The six-hour reporting requirement applies to specified incidents under the Directions; confirm scope and current amendments with counsel/compliance.
MITRE ATT&CK for ICS	Structured taxonomy for adversary tactics and techniques	Use for consistent scenario descriptions, not as a substitute for incident evidence.

6.2 Rogue-device response playbook (one page)

Stage	Action	Owner / timing
1. Alert	Create an event with device identifier, first-seen time, switch/segment, observed protocols and evidence reference.	Sensor → central SOC immediately; preserve timestamps.
2. Triage	Compare with asset register, maintenance ticket, vendor window and network baseline. Check whether the device is expected.	SOC + site OT owner; initial triage target within 15 minutes for the prototype.
3. Safety check	Assess whether the device is interacting with control assets and whether containment could interrupt operations.	Site OT/operations authority; no automated isolation by the prototype.
4. Contain safely	If confirmed unauthorized, have the authorized site/network owner isolate the port or segment under an approved change/emergency procedure. Preserve evidence first where feasible.	Authorized network/OT owner; timing depends on risk and operational safety.
5. Investigate	Review traffic, commands, gateway logs, credentials, change records and affected assets. Determine scope and possible process impact.	SOC + OT engineering + vendor as appropriate.
6. Report	Assess notification obligations under applicable CEA/CERT-In and contractual rules; submit within required timelines where applicable.	Incident commander/compliance; CERT-In directions specify six hours for covered reportable incidents.
7. Recover and learn	Validate safe operation, rotate affected credentials, restore trusted configuration if needed, update inventory/rules and document lessons.	OT owner + SOC; approve return to service.

6.3 Checklist

- Named OT incident owner and escalation contacts exist for every site.
- Asset inventory and vendor-maintenance windows are current.
- Passive sensor health and local evidence retention are monitored.
- Containment decisions are approved by authorized operations personnel.
- Incident classification and reporting obligations are reviewed by compliance/legal staff.
- Evidence timestamps, packet references and decision logs are preserved.

This playbook is a proposed operational workflow, not legal advice. Reporting duties depend on the entity, incident category and applicable instrument; verify the current legal position before operational use.

A6 — Market and Product Positioning

7.1 Competitive landscape

Product / stack	Positioning and visible strengths	Deployment / cost signal	Implication for proposed product
Nozomi Networks	OT/IoT asset visibility, threat detection, risk and incident-response workflows	Commercial platform; pricing generally requires vendor engagement	Compete on small-site affordability, offline resilience and transparent scope—not feature parity.
Claroty	OT/IoT visibility and cybersecurity platform spanning industrial environments	Commercial; pricing typically quote-based	Benchmark protocol visibility, asset context, integrations and enterprise operations.
Dragos	OT-focused threat detection, threat intelligence and response capabilities	Commercial enterprise offering; quote-based	Differentiate on a lightweight entry tier and simple multi-site dashboard.
Tenable OT Security	OT asset discovery, exposure/vulnerability and security visibility	Commercial; current pricing depends on deployment/quote	Show how inventory and alerts complement, not necessarily replace, vulnerability management.
Microsoft Defender for IoT	OT network monitoring and integration with Microsoft security operations ecosystem	Commercial licensing/deployment details depend on offering and environment	Consider integration/export pathways if customer already uses Microsoft security tooling.
Security Onion	Open-source network security monitoring and hunting platform	Software may reduce licence cost but requires infrastructure and expertise	Potential building block; OT-specific parsing and operations need careful validation.
Malcolm	Open-source network traffic analysis stack, including tools for capture and analysis	Open-source project; deployment/operations effort remains a cost	Potential lab and sensor foundation; packaging and field hardening are product work.

7.2 Pricing interpretation

Publicly visible product pages emphasize capabilities but generally do not provide a comparable, universally applicable per-site price. Avoid inventing prices or claiming a specific percentage saving. A fair comparison should request quotes for the same number of sites, assets, retention period, integrations, support level and deployment model. Include total cost of ownership: hardware, software, installation, updates, connectivity, incident support and staff time.

7.3 Who pays and how

Likely buyers include renewable-park owners, independent power producers, operations-and-maintenance providers, utilities, EPC operators and managed-security providers responsible for several sites. A plausible commercial model is a per-site sensor plus annual software/support subscription, with a central dashboard tier based on sites or assets. Pilot pricing should be validated through customer interviews and procurement requirements.

7.4 Product pitch

A lightweight OT security watchman for renewable-energy sites: passively discover plant assets, understand common industrial traffic, flag unexpected devices and risky commands, and send explainable alerts to one central dashboard. It is designed for distributed sites with limited local staff and constrained connectivity. It complements existing controls rather than replacing firewalls, access governance, safety systems or a full OT security program.

A.3 — Design for Part B Prototype

8.1 Prototype objectives

Build an isolated mini-ICR on a laptop using Docker Compose. It must simulate at least three inverters with power, voltage and set-point registers, one RTU/PLC, an IEC-104 link to a fake grid control centre and an HMI/SCADA client polling normally. A passive sensor observes mirrored lab traffic. A dashboard displays inventory, alerts and a timeline.

8.2 Proposed components

Layer	Prototype choice	Purpose
Simulated process	Three Python/pymodbus Modbus TCP inverter services	Generate repeatable normal polling and register values.
Controller / grid interface	OpenPLC and lib60870 IEC-104 component, where practical in the local environment	Represent control and grid-facing communication; document any simplification.
HMI / SCADA	FUXA or ScadaBR, or a lightweight polling client if integration blocks progress	Show that normal polling continues.
Passive sensor	Zeek with suitable CISA ICSNPP parsers and/or Suricata; capture only lab Docker traffic	Extract connection/protocol events without sending control commands.
Inventory and event store	Python service + SQLite or JSONL initially	Track IP/MAC (where observable), protocol, role, first/last seen and alert evidence.
Detection	Policy rules first; Isolation Forest as optional anomaly score on selected flow features	Keep alerts explainable and avoid relying on ML alone.
Dashboard	Streamlit	Display asset table, alert reason, severity, event time and attack timeline.
Packaging	Docker Compose, README, local sample configuration	Reproducible startup and demo.

8.3 Four minimum scenarios to implement

- S1 unknown device: introduce a clearly identified simulated rogue client into the lab network; inventory detects first-seen asset and raises an alert.
- S2 unauthorized write: send a simulated Modbus write from a source not permitted by the policy; alert names source, target register and violated rule.
- S3 unexpected IEC-104 command: if IEC-104 lab traffic is implemented, create a controlled command from a disallowed simulated source and detect it. If protocol implementation is unavailable, disclose the substitution rather than claiming IEC-104 detection.
- S4 abnormal traffic burst: generate a bounded lab-only burst and detect rate/connection deviation; demonstrate that normal polling continues.

8.4 Detection logic and explainability

Use deterministic rules for high-confidence policy violations: unknown asset, disallowed source-to-register write, out-of-window command, unexpected protocol/destination and rate threshold. Use an ML model only for features with a meaningful baseline, such as connection counts, inter-arrival times or bytes per interval. Train on normal lab traffic, keep the train/test split by time or scenario, and do not use attack labels as input features. Each alert should include the rule/model signal, relevant source and destination, timestamp, observed evidence and suggested human check.

8.5 Measurement plan

Assignment target	Measurement method	Reporting caution
Every simulated device found	Compare ground-truth container/device list with inventory after warm-up; report precision/recall of discovery	MAC addresses may not be visible at every capture point; document the network topology.

Assignment target	Measurement method	Reporting caution
≥95% attacks detected	Run the defined scenario set repeatedly; compute detected scenarios / executed scenarios	With only four scenarios, one miss causes 75% detection; add repeated trials and more cases for a meaningful rate.
<5% false alarms	Run normal traffic for a defined duration; false-alert rate = false alerts / defined observation unit	Specify denominator (e.g., false alerts per hour or per asset-hour); do not mix definitions.
Detection under ~15 minutes	Record attack start and alert timestamp; calculate latency	Use synchronized clocks and show per-scenario results.
No impact on control traffic	Compare successful polling, error rate and response latency with sensor off/on	Use repeated runs and report measured results; do not assert no impact without measurement.

8.6 Local-first and slow-link design

The sensor should retain a bounded local event queue and continue detection when the central dashboard is unreachable. When connectivity returns, forward alerts and compact summaries before bulk telemetry. For the optional stretch goal, measure outbound bytes per hour under normal and alert conditions. Ensure queue limits, retention, clock drift and recovery behavior are documented.

8.7 Limitations and risks

- Public datasets may not represent a real solar park; lab scenarios are synthetic.
- Encrypted or proprietary traffic may limit protocol visibility.
- IP/MAC identity can be incomplete across routed or virtualized segments.
- ML anomalies can reflect maintenance or benign operating changes.
- Firmware integrity needs signed vendor metadata, endpoint evidence or configuration records—not only passive packets.
- Do not automatically isolate or block industrial devices in the prototype.

8.8 Acceptance checklist

- Compose starts all required services locally and the README documents setup.
- Normal SCADA polling is visible before attacks.
- Inventory fills with simulated devices and flags an unknown device.
- At least four selected attack scenarios generate correct, explainable alerts.
- Dashboard includes asset inventory, alert reasons and a timeline.
- Measurements include false alerts, detection latency and polling impact.
- Demo video is 5–8 minutes and shows architecture, normal operation, attacks, results and one limitation.

Open Questions and Conclusion

9.1 Three open questions for the in-person discussion

1. Which exact solar-park protocols and vendor equipment are in scope for the first pilot, and can the asset owner provide approved register maps and representative traffic?
2. What procurement, data-residency, retention, support and regulatory obligations would apply to a sensor deployed across multiple developers and operators?
3. What level of evidence is available for remote-access sessions and firmware/configuration changes, and which system owner is authorized to approve containment?

9.2 Conclusion

A low-cost passive watchman is plausible as a visibility and alerting layer, but its value depends on accurate asset context, safe deployment, protocol coverage, useful detections and low operational burden. The strongest prototype is not the one with the most ML; it is the one that reliably explains a small set of meaningful alerts while normal simulated control traffic continues. Part A therefore recommends a rules-first, passive, local-first design with optional ML for anomaly ranking and a central dashboard for multi-site oversight.

The next step is to implement the Part B lab exactly against the design, preserve evidence for each test, and report measured outcomes—including failures and limitations—rather than claiming performance in advance.

References

[1] NIST, SP 800-82 Rev. 3, Guide to Operational Technology (OT) Security, September 2023. https://csrc.nist.gov/pubs/sp/800/82/r3/final

[2] MITRE, ATT&CK for ICS — Tactics. https://attack.mitre.org/tactics/ics/

[3] ISA, ISA/IEC 62443 Series of Standards. https://www.isa.org/standards-and-publications/isa-standards/isa-iec-62443-series-of-standards

[4] Central Electricity Authority (India), CEA Cyber Security in Power Sector Guidelines, 2021. https://cea.nic.in/notification/cea-cyber-security-in-power-sector-guidelines-2021/?lang=en

[5] CERT-In, FAQs on Cyber Security Directions of 28 April 2022. https://www.cert-in.org.in/PDF/FAQs_on_CyberSecurityDirections_May2022.pdf

[6] Nozomi Networks, OT Security Platform. https://www.nozominetworks.com/platform

[7] Dragos, Cybersecurity Platform for OT Environments. https://www.dragos.com/cybersecurity-platform/

[8] Microsoft, Defender for IoT documentation. https://learn.microsoft.com/en-us/azure/defender-for-iot/

[9] Tenable, OT Security product information. https://www.tenable.com/products/ot-security

[10] Claroty, OT/IoT cybersecurity platform. https://claroty.com/

[11] Security Onion, official documentation. https://docs.securityonion.net/

[12] Malcolm, network traffic analysis project. https://github.com/cisagov/Malcolm

[13] CISA, ICSNPP Zeek protocol parsers. https://github.com/cisagov/icsnpp

[14] Wireshark, official documentation. https://www.wireshark.org/docs/

[15] pymodbus documentation. https://pymodbus.readthedocs.io/

[16] OpenPLC Project. https://openplcproject.com/

[17] lib60870 documentation/source. https://github.com/mz-automation/lib60870

[18] Netresec, 4SICS ICS/SCADA packet captures. https://www.netresec.com/?page=PCAP4SICS

[19] ITI ICS-Security-Tools repository. https://github.com/ITI/ICS-Security-Tools

[20] HAI Security Dataset, official project/repository. https://github.com/icsdataset/hai

[21] iTrust, SWaT/WADI testbed and research resources. https://itrust.sutd.edu.sg/

[22] ATT&CK for ICS should be used alongside primary incident reports for Ukraine grid incidents, Industroyer/Industroyer2, TRITON/TRISIS, KA-SAT, RedEcho and Volt Typhoon. Incident-specific source citations should be added after selecting and reviewing each primary report.

[23] Cognton AI, “Who Is Watching the Solar Farm’s Network?” Student exercise, supplied assignment, pp. 1–5.

Source verification and limitations

Official standards, regulator and vendor pages were used to ground the framework, product capability and regulatory references. Vendor feature descriptions are not independent performance evaluations. Pricing was not publicly comparable in the reviewed pages and is therefore described qualitatively. Dataset names such as “CIC Modbus 2023,” “Electra,” “Mississippi State power-system datasets” and “IEC-104 datasets” must be pinned to exact releases and licences before experimental use. Incident summaries are high-level; the final submission should attach a primary source to each case-study row and avoid unsupported attribution.